

SAM10 INFRASTRUCTURE DESIGN DOCUMENT

Comprehensive AWS Cloud Infrastructure Blueprint for MediCare Direct System

Student Name:	Robert Angel B. Santiago	Student ID:	23-1360-266
Course & Section:	SAM10 — BSIT-4-A	Instructor:	Romack L. Natividad, MIT
Target AWS Region:	ap-southeast-1 (Singapore)	VPC Network CIDR:	10.0.0.0/16

SECTION A: SYSTEM OVERVIEW & WORKLOAD ANALYSIS

System Description & Purpose (~120 Words): MediCare Direct is an enterprise outpatient clinic management system engineered to digitize patient appointment scheduling, physician availability tracking, and clinical record management. The platform caters to three distinct user personas: (1) **Patients** accessing the public web portal to register, view consultation schedules, and reserve appointments; (2) **Healthcare Providers and Staff** managing clinical queues, doctor rosters, and electronic health records (EHR); and (3) **Cloud Administrators** maintaining 99.9% infrastructure availability, automated snapshot retention, and regulatory compliance.

Infrastructure Workloads & Operational Flow: To support these user personas, the system requires three distinct compute and storage workloads: a public web reverse proxy handling SSL/TLS termination and static web assets; an isolated application API processing business scheduling logic; and a highly secure PostgreSQL database tier storing patient records. All workloads are deployed inside a logically segmented Virtual Private Cloud (VPC) in the AWS Singapore region (ap-southeast-1), ensuring strict data confidentiality, operational isolation, and regulatory compliance.

SECTION B: VPC & SUBNET DESIGN

CIDR Allocation & Subnet Segmentation: The cloud foundation uses a primary VPC CIDR block of **10.0.0.0/16**, providing 65,536 private IP addresses. To isolate workloads according to security exposure, the VPC is partitioned into three distinct /24 subnets (251 usable host IPs per subnet): a Public Subnet (10.0.1.0/24) for web servers, a Private Application Subnet (10.0.2.0/24) for API endpoints, and a Private Data Subnet (10.0.3.0/24) dedicated exclusively to database persistent storage.

Subnet Isolation Rationale & Multi-AZ Readiness: Public and private resources are separated so that an external compromise of the public web proxy cannot grant immediate access to sensitive database stores. The subnet addressing scheme reserves contiguous CIDR blocks (e.g., 10.0.10.0/24, 10.0.20.0/24) for future Multi-AZ expansion across Availability Zones ap-southeast-1b and ap-southeast-1c without requiring network re-IPing.

Subnet Name	CIDR Block	Subnet Type	Hosted Resources & Security Boundary
Public Subnet 1	10.0.1.0/24	Public Tier	Web EC2 (t3.micro), NGINX proxy, IGW route table.
Private App Subnet 1	10.0.2.0/24	Private Tier	App EC2 (t3.small), Node.js API, No IGW route.
Private Data Subnet 1	10.0.3.0/24	Private Tier	DB EC2 (t3.small), PostgreSQL 15, KMS-encrypted EBS.

SECTION C: NETWORK & ROUTING DESIGN

Route Table & Gateway Architecture: An Internet Gateway (IGW) is attached at the VPC boundary to allow controlled public ingress and egress. The **Public Route Table** contains a default route (0.0.0.0/0 -> IGW) and is explicitly associated with the Public Subnet (10.0.1.0/24). In contrast, the **Private Route Table** contains only the local VPC route (10.0.0.0/16 -> local) with no route to the Internet Gateway. This ensures that resources in the Private App and Data subnets remain completely unreachable from direct Internet probes.

Directional Traffic Flow & Network Boundaries: 1. *External Web Traffic:* Public Internet users connect to the Web Server via HTTPS on Port 443 through the Internet Gateway. 2. *Application Ingress:* The Web Reverse Proxy inspects and forwards validated API calls to the Application API Server on Port 5000. 3. *Database Traffic:* The Application Server executes queries against the PostgreSQL Database on Port 5432 over internal VPC routing. 4. *Blocked Paths:* Direct Internet traffic to Private App and Data subnets is dropped at the routing layer.

SECTION D: COMPUTE & STORAGE DESIGN

Compute Sizing & Software Stack: All workloads run on Amazon EC2 instances powered by Amazon Linux 2023. Instance families and initial sizes were selected to match expected CPU, memory, and baseline network throughput for outpatient clinic operations:

Compute Role	Instance Type	OS & Software Stack	EBS Volume	Subnet Placement
Web Server	t3.micro (2 vCPU, 1 GB)	Amazon Linux 2023 / NGINX	20 GB gp3	Public Subnet (10.0.1.0/24)
Application Server	t3.small (2 vCPU, 2 GB)	Amazon Linux 2023 / Node.js Express	30 GB gp3	Private App Subnet (10.0.2.0/24)
Database Server	t3.small (2 vCPU, 2 GB)	Amazon Linux 2023 / PostgreSQL 15	100 GB Encrypted gp3	Private Data Subnet (10.0.3.0/24)

EC2 vs. Serverless Architectural Justification: EC2 was selected over serverless alternatives (AWS Lambda or Elastic Beanstalk) because MediCare Direct requires full OS-level administrative control for custom Linux kernel tuning, stateful database connection pooling, and predictable 24/7 baseline operational expenses without serverless cold-start latency spikes.

Storage, KMS Encryption, & Backup Policy: Persistent storage is provided by General Purpose SSD (gp3) EBS volumes offering 3,000 baseline IOPS and 125 MB/s throughput. The database volume (100 GB) is encrypted at rest using **AWS Key Management Service (KMS)** with AES-256 encryption. Automated daily EBS snapshots are executed via **AWS Backup** lifecycle policies, retaining backups for 30 days to ensure disaster recovery readiness.

Security Group Firewall Rules: Inbound network access is strictly governed using stateful Security Groups with Security Group ID chaining, ensuring that firewall rules reference source Security Group IDs rather than open IP ranges:

Security Group	Allowed Port / Protocol	Traffic Source	Architectural Security Purpose
sg-WebTier	Port 80 (HTTP) & 443 (HTTPS)	0.0.0.0/0 (Internet)	Serves public patient portal & redirects HTTP to HTTPS.
sg-AppTier	Port 5000 (Custom TCP)	sg-WebTier (Security Group ID)	Restricts API access strictly to Web Proxy instances.
sg-DBTier	Port 5432 (PostgreSQL)	sg-AppTier (Security Group ID)	Restricts DB queries strictly to Application API instances.

IAM Governance & Administrative Access: Public SSH (Port 22) is completely disabled across all instances. Administrators connect securely using **AWS Systems Manager (SSM) Session Manager**, providing encrypted, IAM-authenticated shell access with full CloudWatch session logging. Administrative identities are governed via Role-Based Access Control (RBAC): the AWS Root User is locked down with hardware MFA; routine tasks use dedicated roles: CloudAdminRole (infrastructure), SysAdminRole (EC2/EBS), and ReadOnlyAuditRole (compliance).

AWS Root Account

- Emergency Break-Glass Only
 - Hardware MFA Required
- **No Day-to-Day Operations**

Access Security

- SSH Port 22 Closed
- AWS SSM Sessions
 - Full Audit Trail
 - KMS Encrypted

CloudAdminRole

Approved infrastructure modifications, VPC/Subnet provisioning, Security Group policies.

[MFA Req]

SysAdminRole

EC2 lifecycle management, EBS snapshot retention, SSM Session Manager administration.

[MFA Req]

ReadOnlyAuditRole

ReadOnlyAccess policy for compliance verification, audit logging, and CloudWatch metrics.

SECTION F: REPRODUCIBLE COST ESTIMATION & OPTIMIZATION

Cost Basis & Pricing Parameters: Costs were calculated using the AWS Pricing Calculator for the **ap-southeast-1 (Singapore)** region (Pricing Date: September 2026, Billing Model: On-Demand). Total monthly baseline infrastructure cost is **\$75.98 / month** (\$911.76 / year):

AWS Service Component	Configuration & Pricing Basis	Quantity / Usage	Monthly Cost (\$)
EC2 Web Server	t3.micro On-Demand (\$0.0144/hr)	1 instance (730 hrs)	\$10.51
EC2 Application Server	t3.small On-Demand (\$0.0288/hr)	1 instance (730 hrs)	\$21.02
EC2 Database Server	t3.small On-Demand (\$0.0288/hr)	1 instance (730 hrs)	\$21.02
EBS gp3 Storage	150 GB total capacity (\$0.092/GB-mo)	150 GB-month	\$13.80
Public IPv4 Address	In-use Public IP (\$0.005/hr)	730 hours	\$3.65
CloudWatch & Data Transfer	Logs (2 GB) + Data Out (15 GB)	Standard Usage	\$3.48
EBS Snapshots / Backup	AWS Backup Snapshot Storage (\$0.05/GB)	50 GB-month	\$2.50
TOTAL ESTIMATED COST	AWS Region: ap-southeast-1 (Singapore)	Monthly Total	\$75.98 / mo

Cost Optimization Strategies: (1) Purchasing a 1-Year Compute Savings Plan for baseline instances reduces EC2 runtime costs by up to 34% (~\$17.80/month savings). (2) Configuring AWS Lifecycle Manager to automatically delete EBS snapshots older than 30 days prevents storage cost creep.

SECTION G: EXPLANATION OF MAJOR DESIGN DECISIONS

The proposed architecture strictly implements the 5 AWS Cloud Architectural Lenses: 1. **Segmentation:** Decouples public web traffic from sensitive backend databases using dedicated subnets. 2. **Least Privilege:** Restricts firewall ingress strictly to required ports and Security Group IDs. 3. **Controlled Connectivity:** Routes public traffic through an Internet Gateway while keeping private subnets offline. 4. **Scalability:** /24 CIDRs accommodate 250+ hosts per subnet for future Auto Scaling and Load Balancers. 5. **Simplicity:** Omits unneeded complex managed services to keep operational overhead low (\$75.98/month baseline).

Submitted By (Student)	Submitted To (Instructor)	Course & Academic Institution
Robert Angel B. Santiago Student ID: 23-1360-266 Section: BSIT-4-A	Romack L. Natividad, MIT Instructor, SAM10 AUF CCS Faculty	SAM10 Systems Administration Angeles University Foundation College of Computer Studies